Sushant Poudel

AI Security Engineer — agent tool-boundary abuse, memory safety, security tooling

Bhaktapur, Nepal | sushant.poudel2028@gmail.com
github.com/sushant-me | linkedin.com/in/sushant-poudel2028 | sushantpoudel2028.com.np | HackingHub **nofear976**

I work on the failure mode where an autonomous agent does something a human would have blocked: prompt injection through retrieved content, tools that shadow framework built-ins, confirmation gates that fail open, and the memory-safety bugs underneath the libraries agents are built on. Two years of full-time engineering, a security patch merged into `google/go-github`, five open memory-safety issues in `google/s2geometry`, seven accepted or presented papers and four released security tools of my own.

Every claim below names its public source and is re-checked weekly. `github.com/sushant-me/reputation` holds each one with its source and runs the checks in CI; it goes red when one stops holding. Reproduce with `git clone … reputation && python3 verify_evidence.py`

SELECTED RECORD

- **HackingHub — 7th on the all-time global leaderboard** — 210 flags, 21,785 XP, 1 gold, 4 silver and 3 bronze awards. Receipt: all-time leaderboard API. The Q3 2026 period closed with the account at the top of that period's board (177 flags, 18,125 XP); the per-period board has since rolled to Q4 and is no longer served.
- **NullOrigin CTF 2026** (international, 24-hour) — finished **2nd of the eight teams in the Grand Finale with team `roamers`: 16,850 points, 40 of 42 challenges solved** (final standings: 1st Jokers 17,600, 2nd roamers 16,850; window closed 25 September 2026); Grand Finale Certificate awarded 26 September 2026 (ID NO-2026-GF-229CF4, verifiable at creds.cyberhx.com)
- **Security patch authored, merged, then superseded into `google/go-github`.** I authored **#4556**, merged by the maintainer on 2026-09-17: a release-asset upload whose URL pointed at a different host than the configured upload host was refused rather than sent with the client's credentials. He reverted it the next day in favour of his broader **#4564**, which enforces *"credentials are sent only to configured origins"* and is what master implements today — its pull-request history carrying the commit *"Address feedback from sushant-me"*. The maintainer then offered the AUTHORS route for the lost squash-merged commit: I opened **#4579**, and **Sushant Poudel** is now in the project's `AUTHORS` file on master.
- **Five open memory-safety issues in `google/s2geometry`**, each with a standalone reproducer: a NULL dereference on the documented traversal path (#674), an out-of-bounds access from an unchecked shape id (#676), a 16 GiB allocation driven by a **117-byte input** (#677), a heap-buffer-overflow in `EncodedS2LaxPolygonShape::edge` (#678), and a 2.4 GiB allocation reachable from a 28-byte input (#679).
- **Two hardening pull requests under review in `google/s2geometry`**, split at the maintainer's request: **#681** validates `loop_starts` when decoding a lax polygon shape; **#682** bounds untrusted counts in `S2ShapeIndexCell::Decode`. A third change was withdrawn after AddressSanitizer showed the crash it claimed to fix was the `loop_starts` out-of-bounds read.
- **An OSS-Fuzz harness that was testing nothing** — `google/libphonenumber`'s as-you-type formatter asserted 0.00% line coverage of the code it targeted because it never generated valid input. A local rebuild of the same target measured **23.50%** before and **93.05%** after the proposed fix (PR #4079, open) - the published report's 0.00% is a different measurement of the same file.
- **MCP tool shadowing across Google's agent frameworks** — framework-reserved tool names a server-supplied tool could occupy, bypassing the duplicate-name guard: the `adk-python` fix was merged via Copybara (`#7145`) and `adk-go #1606` is open; on the Java side both the fix pull request (`#1515`) and the tracking issue (`#1513`) were closed by the maintainer, for consistency across the ADK frameworks.
- **Detection rules for agentic CI pipelines at Trail of Bits** — authored rules identifying unbounded tool targets and AI-action tool-pattern abuse in GitHub Actions workflows.
- **Maintainer of four released security tools, and a benchmark that measures them:** agentbound (static detector for agent tool-boundary bugs), mcpaudit (v0.1.1 — audits an MCP server's tool declarations before you connect and pins them, so a description edited after approval is a reported diff; 74 tests), mcp-nameguard, trajectorycheck — each with tests, releases and CI.
- **Author of a labelled benchmark:** tool-boundary-corpus — 23 agent tool-boundary cases and a detector-agnostic harness. It found a false positive in my own released detector: precision went 0.750 to 1.000, and the failing case stayed in CI rather than being deleted.

EXPERIENCE

AI Engineer — Atmos SoftTech Pvt. Ltd.

Birgunj, Nepal · March 2024 – March 2026 · full-time

- Designed, developed and deployed AI-based systems and machine-learning models in production, owning features from data preparation through deployment and monitoring.
- Built and maintained full-stack web applications — front-end, back-end services, databases, authentication and release automation.
- Engineered autonomous agent systems: tool-calling pipelines, multi-step orchestration, retrieval over private local data, and offline-first inference where sending data to a cloud API was not acceptable.
- Conduct and performance rated highly satisfactory in the company's signed experience letter (Md. Samsad Ali, CEO) — available on request.

Research Engineer — Arvion

Remote, part-time · from June 2026

- Continued employment confirmed after a three-month trial period, at a monthly stipend of NRS 22,500.

Technical Lead & Software Developer — Avatar Tech Solutions Pvt. Ltd.

Kathmandu, Nepal · December 2025 – June 2026

- Architected, built and deployed the company's corporate web ecosystem and a responsive mobile application as full-stack technical lead.
- Ran enterprise IT operations for 30+ workstations: setup, network configuration and zero-downtime maintenance; built an automated inventory system replacing manual record-keeping.

AI Intern — Next AI and Eminence Ways · Fundamentals Intern — Nobel Learning PBC

Bhaktapur, Nepal · Remote (United States) · April – August 2026

- Engineered and tested applied AI solutions focused on advanced speech recognition, and prototyped solutions bridging theoretical AI concepts and practical implementations.
- Completed a 90-hour international Learner-to-Leader program spanning web design, strategic pitching and project execution.

PUBLICATIONS

- **LLM Agent Firewall: Real-Time Detection and Neutralization of Prompt Injection in Multi-Agent Systems** — Paper ID 4005. Accepted for **oral presentation** at the 2nd IEEE International Conference on Cybersecurity and AI-Based Systems (Cyber-AI 2026), Bucharest. Runtime detection and neutralisation of prompt injection between cooperating agents, where the injection arrives inside tool output rather than in the user's turn.
- **Evaluating Google's Open Knowledge Format (OKF v0.1) for Multi-Agent Threat Intelligence: A Proof-of-Concept in Digital Forensics** — accepted at IC-AICSE 2026 (International Conference on Artificial Intelligence in Computational Science and Engineering), 7 October 2026, hybrid.
- **A Hybrid Causal-Generative Multi-Agent Framework for Secure Autonomous Mechatronics** — Paper ID 1571313313, with A. Pandey. Accepted at the 4th IEEE International Conference on Artificial Intelligence and Mechatronics Systems (AIMS 2026); presented virtually 23–24 July 2026; submitted to IEEE Xplore.
- **Edge-Native Semantic Firewall for Autonomous LLM Agents: A Structured Chain-of-Thought Verification Framework** — accepted at PUBLISHED - Proceedings of the International Conference on Innovation in Computing, Science, Engineering and Technology (ICICSET), 2 October 2026. DOI: 10.65091/icicset.v3i1.75 | https://doi.org/10.65091/icicset.v3i1.75 With R. Pandey and A. Pandey (Nepal Engineering College). A 3.8B model (Phi-3-mini, 4-bit) on one consumer laptop inside a 4.2 GiB VRAM budget, 600 policy scenarios per condition, no cloud inference. JSON-constrained output without a reasoning field was the least safe arm (46.2% unsafe accepts vs 17.2% unconstrained); structured CoT cut false accepts of irreversible hard-denial commands from 71 to 6 at 66.3% decision accuracy.
- **PREBAS: Preemptive Bandwidth Scaling for WebRTC in LEO Satellite Networks Using Lightweight Neural Prediction** — accepted, 2026 IEEE RTC, Chicago, USA. Predictive rate scaling ahead of link degradation instead of reacting to it.
- **Hybrid Causal-Generative Multi-Agent Framework** (preprint, 2026) — a Causal Safety Enforcer applying Pearl's do-calculus to prompt-injection actuation in disaster networks; and **Project Swayam** (Municipal AI Governance Conference) — an air-gapped sovereign AI system with a quantized local model behind a deterministic gatekeeper.

LEADERSHIP & RECOGNITION

- **Two-time Hult Prize 1st Runner-Up** (2024 and 2025) for social-entrepreneurship technology solutions.
- **Aspire Leaders Program Global Finalist** (2025) — selected from 54,000+ applicants for Harvard faculty training.
- **NEC IT Club Joint Secretary** and hackathon organiser.

PROJECTS

- **VaultChat** — peer-to-peer encrypted platform disguised as a calculator with a hidden virtual-machine partition (Flutter, steganography). **GhostSignal** — Wi-Fi CSI and mesh rescue system detecting chest movement under rubble (ESP32, penetration-tested).
- **Mero-Bazaar-Secured** (52 pre-publication vulnerabilities closed), **Dhukuti Pay** (offline peer-to-peer wallet) and **NetGuardian** (network diagnostics); **Arth-Sathi / Smart NEPSE** — generative AI financial analyst with an LSTM news-ranking engine.

SKILLS

Agent & LLM security: prompt injection (direct and via retrieved content), MCP tool shadowing, tool-boundary and confirmation-gate analysis, policy evaluation with a local model, red-teaming and failure taxonomies.

Memory safety & fuzzing: libFuzzer/AFL++, harness engineering and coverage analysis, ASan/UBSan triage, GDB, C/C++ bisection of decode paths, OSS-Fuzz, CodeQL.

ML engineering: PyTorch, TensorFlow/Keras, quantized local inference (GGUF/llama.cpp), RAG and LangChain, transformers and state-space models implemented from scratch, evaluation design with controls.

Engineering: Python, Go, Java, C/C++, TypeScript/Next.js/React, Node.js, Flutter/Dart, Docker, Linux, Git, GitHub Actions CI/CD. PyTest, Jest, Cypress, Selenium, Postman.

EDUCATION & CERTIFICATION

Bachelor in Computer Engineering, Nepal Engineering College (NEC), Bhaktapur — . | **High School (Science — Physics/Maths)**, St. Xavier's School, Jawalakhel, 2020–2022.

IBM AI Engineering · IBM DevOps and Software Engineering · Google Cybersecurity · Google UX Design · DeepLearning.AI Deep Learning · Stanford Machine Learning · Flutter & Dart (Packt) · plus 20+ further certificates.

Publication statuses, leaderboard positions and upstream contributions are stated exactly as their public sources report them — an accepted paper with the camera-ready in progress is not called published, a superseded pull request is not called the current implementation, and an open pull request is not called merged.